2 Secure API development

This chapter covers

- Setting up an example API project
- Secure development principles
- Common attacks against APIs
- Input validation and producing safe output

I've so far talked about API security in the abstract but in this chapter, you'll dive in and look at the nuts and bolts of developing an example API. I've written many APIs in my career and now spend my days reviewing the security of APIs used for critical security operations in major corporations, banks, and multinational media organizations. Although the technologies and techniques vary from situation to situation and from year to year, the fundamentals remain the same. In this chapter you'll learn how to apply basic secure development principles to API development, so that you can build more advanced security measures on top of a firm foundation.

2.1 The Natter API

You've had the perfect business idea. What the world needs is a new social network. You've got the name and the concept: *Natter* – the social network for coffee mornings, book groups, and other small gatherings. You've defined